


```
$ ./think_like_a_hacker
```

فكّر كهاكر أخلاقي

Think Like an Ethical Hacker

افهم كيف يفكّر المهاجم... لتحمي نفسك وبياناتك وأجهزتك.

م. محمد الهاشم | ٣١/١٠ · ٧:٠٠ مساءً | فندق جراند دي الأحساء

خذ العرض معك

امسح الرمز لتحميله PDF على جوالك

⬇ تحميل PDF

[00] ٣ ساعات · نظري + تجارب حيّة

خريطة الورشة

01 — 40 min
عقلية الهاكر
كيف يفكّر المهاجم، ومنهجيته، وأخلاقيات المجال

02 — 30 min
صندوق أدوات المهاجم
ماذا يستطيع أن يفعل على الشبكة وعلى جهازك؟

03 — 40 min
كشف الخدعة
التصيّد والروابط المزيّفة + تجربة حيّة

04 — 40 min
الدرع الرقمي
خطوات عملية تحمي حساباتك وأجهزتك

05 — 20 min
تحدٍّ وخلاصة
حلّوا سيناريوهات واقعية بأنفسكم

10 min
استراحة ☕

[00] لماذا نتعلّم كالهاكر؟

نتعلّم الهجوم... لنُتقن الدفاع

لا يمكنك أن تحمي نفسك من خدعة لا تعرف كيف تعمل. اليوم ننظر للأمور بعين المهاجم — لا لنؤذي، بل لنكتشف الثغرات قبل أن يستغلّها غيرنا.

قاعدة اليوم

لا تُجرّب أي تقنية إلا على أجهزتك وحساباتك أنت، أو بإذنٍ مكتوب. الاختراق بدون إذن جريمة يعاقب عليها القانون — وهذا بالضبط ما يفرّق الهاكر الأخلاقي عن المجرم.

01

[PART 01 · 40 min]

عقلية الهاكر

كيف يفكّر المهاجم — ولماذا يهمّك أن تعرف ذلك

[01] قصة حقيقية · Uber · سبتمبر ٢٠٢٢

كيف اختُرقت شركة عملاقة... برسالة واتساب؟

STEP 01

كلمة مرور مسروقة

لموظف متعاقد — سُرقت غالبًا ببرمجية خبيثة على جهازه الشخصي.

STEP 02

سيل من طلبات التحقق

أغرق جواله بإشعارات «هل تحاول تسجيل الدخول؟» مرة بعد مرة.

STEP 03

«أنا من الدعم الفني»

راسله على واتساب: «وافق على الطلب لتتوقف الإشعارات».

STEP 04

ضغطة «موافق» واحدة

فدخل المهاجم إلى أنظمة الشركة الداخلية.

لم يكسر المهاجم أي تشفير — **أقنع إنسانًا واحدًا أن يفتح له الباب.**

[01] البداية من التعريف

ما هو الاختراق؟

ببساطة: الوصول إلى شيء لا يحقّ لك الوصول إليه.

تدخل حساب شخص آخر

بريده أو حسابه في التواصل — حتى لو «للمزح»

تقرأ بيانات ممنوعة

ملفات أو رسائل أو سجلات ليست من حقّك

تتحكّم بجهاز ليس لك

كاميرا، جوال، أو حاسب — عن بُعد ودون إذن صاحبه

> observe --small-details_

الاختراق ليس سحرًا

إنه فنّ ملاحظة **التفاصيل الصغيرة** التي يتجاوزها الجميع.

منشور يكشف تاريخ ميلادك

باب نسي أحدهم قفله

صورة مكتب تكشف كلمة مرور

[01] طريقة التفكير

السؤال السحري: «ماذا لو؟»

الشخص العادي يسأل:

«كيف يعمل هذا النظام؟»

الهاكر يسأل:

«ماذا لو فعلتُ ما لم يتوقّعه المطوّر؟»

01

جمع المعلومات

يلاحظ كل ما هو معلن، دون افتراضات

←

02

التحليل والربط

يحدّد الحلقة الأضعف ويقدّر حجم الخطر

←

03

التجربة والحل

يختبر فرضيته — بإذن — ثم يقترح الحماية

[01] الخطوة ١ عمليًا · لا حاجة لحفظها

كيف يبدأ الهاكر؟ يرسم خريطة

recon@lab:~

```
$ ping example.com
↳ الجهاز متصل ويردّ ✓
$ scan example.com
↳ port 80 → (مفتوح) موقع ويب
↳ port 22 → (مفتوح) دخول عن بُعد
↳ كل باب مفتوح = نقطة دخول محتملة
```

قبل أي هجوم، يجمع الهاكر كل ما يستطيع: ما المتصل؟ ما الأبواب المفتوحة؟ ماذا ينشر الناس عن أنفسهم؟ **وأنت تحمي نفسك بتقليل ما تكشفه للعالم.**

[01] نفس المهارة... نوايا مختلفة

أنواع الهاكرز

BLACK HAT

القبعة السوداء

يخترق للسرقة أو الابتزاز أو الأذى. هذا هو «المجرم الإلكتروني».

WHITE HAT · YOU

القبعة البيضاء

نفس المهارات تمامًا — لكن بإذن رسمي، لاختبار الأنظمة وإصلاحها. هذا هو الهاكر الأخلاقي.

GREY HAT

القبعة الرمادية

يخترق بلا إذن لكن بلا نيّة سرقة، وقد يبلّغ لاحقًا. نيّته قد تكون طيبة... لكن عمله يبقى غير قانوني.

الإذن هو الفيصل: مختص الأقفال الذي يفتح بيتك بطلبك يقدّم خدمة، ومن يفتحه دون علمك لصّ. الأدوات واحدة، والفرق هو الإذن.

[01] أخلاقيات المجال

٤ قواعد يلتزم بها الهاكر الأخلاقي

01

الإذن المكتوب

لا اختبار قبل موافقة رسمية مكتوبة

02

النطاق المحدد

يختبر ما اتُّفق عليه فقط، دون أي تجاوز

03

السرّية التامة

يحمي أي بيانات يطّلع عليها أثناء الاختبار

04

الإبلاغ المسؤول

يُبلغ الجهة بشكل خاص حتى تُصلح الثغرة



BUG BOUNTY

برامج مكافأة الثغرات

شركات كبرى مثل Google تدفع مكافآت مالية لمن يكتشف ثغرة ويبلّغ عنها بمسؤولية — بشرط الالتزام بهذه القواعد.

[01] فرص حقيقية

لماذا يحتاج العالم هاكرز أخلاقيين؟

مجال مطلوب ومتنامٍ
الطلب على متخصصي الأمن السيبراني في تزايد مستمر

الشركات توظّفهم
يدفعون لهم ليخترقوا أنظمتهم قبل أن يفعلها المجرمون

تبدأ من الآن
منصات تدريب مجانية وشهادات للمبتدئين — المصادر في آخر العرض

الذكاء الاصطناعي
جعل الهجوم أسهل على الجميع — فازداد الطلب على المدافعين

[PART 02 · 30 min]

02

صندوق أدوات المهاجم

اعرف ما هو ممكن... لتعرف كيف تحمي نفسك

للفهم والحماية فقط — استخدامها على غيرك دون إذن جريمة

[02] المدخل لكل شيء

الرجل في المنتصف (Man-in-the-Middle)



المهاجم يضع نفسه بينك وبين الإنترنت — **فيمرّ عليه كل ما ترسله وتستقبله.**

أين يحدث؟

- واي فاي مفتوح في مقهى أو مطار
- شبكة مزيّفة باسم مغرٍ: «Free_WiFi»
- جهاز مخترق على نفس شبكتك

[02] هجمات على الشبكة · تعمل عندما يكون المهاجم «في المنتصف»

٤ أدوات تعمل على الطريق بينك وبين الإنترنت

المتنصّت على الشبكة

Packet Sniffer

يلتقط البيانات المارّة في الشبكة ويقرأ غير المشفّر منها — كمن يقرأ البطاقات البريدية قبل أن تصل.

درعك: مواقع HTTPS فقط، وVPN على الشبكات العامة.

مزوّر العناوين

DNS Spoofer

الـDNS هو «دليل هاتف» الإنترنت. المهاجم يغيّر الرقم، فتصل لموقع مزيّف رغم أنك كتبت الاسم الصحيح.

درعك: لا تتجاوز أبدًا تحذير «الاتصال غير آمن» في المتصفح.

حاقن الشيفرة

Code Injector

يدسّ شيفرة في صفحة غير مشفّرة وهي في طريقها إليك — مثل نافذة «حدّث متصفحك الآن» مزيّفة.

درعك: HTTPS، وتجاهل النوافذ المفاجئة على الشبكات العامة.

مبدّل الملفات

File Interceptor

يعترض ملفًا تنزّله، ويستبدله بنسخة مُلغّمة تحمل نفس الاسم والشكل.

درعك: نزّل من المتجر أو الموقع الرسمي فقط — وليس على شبكة عامة.

[02] هجمات على جهازك · تعمل بعد أن يدخل شيء إلى جهازك

٣ ضيوف خفيّون قد يسكنون جهازك

Malware

البرمجيات الخبيثة

اسم شامل لأي برنامج مؤذٍ: فيروس، برنامج فدية يقفل ملفاتك، برنامج تجسّس...

يأتي من: مرفقات مجهولة، ألعاب وبرامج «مكرّكة»، تطبيقات مزيّفة.

درعك: المتجر الرسمي، التحديثات، ومضاد الفيروسات.

Backdoor

الباب الخلفي

مدخل سرّي يتركه المهاجم في جهازك ليعود متى شاء — دون كلمة مرور.

علامات: تطبيقات لا تعرفها، بطء مفاجئ، استهلاك غريب للبطارية أو البيانات.

درعك: راجع تطبيقاتك وصلاحياتها، وحدّث نظامك.

Keylogger

مسجّل لوحة المفاتيح

يسجّل كل حرف تكتبه — كلمات المرور والرسائل — ويرسلها للمهاجم.

قد يكون برنامجًا خفيًا، أو قطعة صغيرة موصولة بجهاز عام.

درعك: التحقق بخطوتين، ولا تدخل حساباتك من أجهزة عامة.

[02] كيف تعمل الأدوات معًا؟

قصة هجوم كامل... في مقهى

01 · Man-in-the-Middle

تتصل بـ«Free_Cafe_WiFi»

الشبكة أنشأها المهاجم نفسه — فصار في المنتصف.

02 · Packet Sniffer

يرى ما تتصفّحه

كل صفحة غير مشفّرة تمرّ أمامه بوضوح.

03 · DNS Spoofer

تكتب اسم موقع مشهور...

فيوجّهك بهدوء إلى نسخة مزيّفة منه.

04 · Code Injector

تظهر نافذة «حدّث متصفحك»

دسّها المهاجم في الصفحة وهي في طريقها إليك.

05 · File Interceptor

تضغط «تحميل»...

فيصلك برنامج خبيث (Malware) يحمل اسم التحديث نفسه.

06 · Backdoor + Keylogger

النتيجة: جهازك صار له

باب خلفي يعود منه متى شاء، ومسجّل يسرق كل كلمة مرور تكتبها.

كان يمكن إيقافها من الخطوة الأولى: شبكة موثوقة أو VPN · مواقع HTTPS · التحميل من المصدر الرسمي · التحقق بخطوتين.

[02] الخبر الجيد

٤ دروع توقف معظم هذه الأدوات

HTTPS — القفل في المتصفح

يشفّر ما بينك وبين الموقع، وينبّهك عند التزوير

يوقف:

- DNS Spoofer
- Code Injector
- Packet Sniffer

VPN أو شبكة موثوقة

على الشبكات العامة، أو استخدم بيانات جوالك

يوقف:

- Packet Sniffer
- Man-in-the-Middle

المصدر الرسمي + التحديثات

نزّل من المتجر الرسمي، وحدّث نظامك وتطبيقاتك

يوقف:

- Backdoor
- Malware
- File Interceptor

التحقق بخطوتين

كلمة المرور المسروقة وحدها لا تكفي للدخول

يوقف:

- Keylogger

لا يوجد درع واحد يكفي — **اجمعها كلها، فتصبح هدفًا صعبًا يتجاوزه المهاجم.**

03

[PART 03 · 40 min]

كشف الخدعة

كيف تفرّق بين الحقيقي والمزيّف — ولا تقع في الفخّ

> target = human_

المهاجم يستهدف الإنسان قبل الجهاز

لماذا يكسر التشفير... إذا كان يستطيع أن يقنعك أنت بفتح الباب؟

[03] العنصر البشري: الحلقة الأضعف

٣ عادات يراهن عليها المهاجم

تكرار كلمة المرور
نفس الكلمة في كل مكان — وسهلة التخمين من عاداتنا

تأجيل التحديثات
ثغرات معروفة تبقى مفتوحة لأسابيع وشهور

الثقة الزائدة والفضول
فتح رسائل ومرفقات مجهولة «لنرى ما فيها»

ROOT CAUSE

أغلب الاختراقات ليست تعقيدًا تقنيًا

بل كلمة مرور ضعيفة، أو رابط ضُغط بلا تفكير، أو إعدادات تُركت كما هي.

[03] أشهر خدعة في العالم

ما هو التصيّد؟ (Phishing)

رسالة أو صفحة تتظاهر بأنها جهة تثق بها لتعطيها معلوماتك بنفسك.

⚠ تمامًا مثل الصيّاد: يضع طُعمًا جذّابًا — رسالة عاجلة، جائزة، تحذير — وينتظر أن «تعضّ» الطُعم.

يصلك عبر: بريد · رسالة SMS · واتساب · مكالمة · رمز QR

[03] تجربة حيّة ● LIVE

هل هذه صفحة دخول حقيقية؟

01 امسح رمز QR بجوالك — أو اضغط الرابط

02 اكتب بريدًا وكلمة مرور **وهميّين**

03 اضغط «تسجيل الدخول»... وشاهد المفاجأة

⚠ بيانات وهميّة فقط — لا تُدخل كلمة مرورك الحقيقية أبدًا



Plixo

اضغط لفتح Plixo ↗

تعمل على جهازك فقط ولا تحفظ أي شيء

[03] ماذا حدث في التجربة؟

لو كانت صفحة مهاجم... لسُرقت بياناتك

الصفحة تشبه التطبيق الحقيقي تمامًا. لو كانت من مهاجم، لوصله كل ما كتبتَه فورًا. ثلاثة دروس:

١. أنت من سلّم البيانات

لم يخترق أحدٌ جهازك؛ الخدعة جعلتك تكتبها بنفسك.

٢. الشكل المتقن لا يعني الأمان

نسخ تصميم أي موقع وشعاره يحتاج دقائق فقط.

٣. انظر إلى الرابط، لا إلى الشكل

عنوان الصفحة لم يكن الموقع الرسمي — وهذا وحده يكشف الخدعة.

✓ اطمئن: صفحة Plixo لم تحفظ ولم ترسل أي شيء

[03] مهارة تحميك كل يوم

كيف تعرف الموقع الحقيقي من الرابط؟

القاعدة: انظر إلى ما قبل أول «/». **آخر جزأين هناك هما الموقع الحقيقي** — وكل ما قبلهما يستطيع المحتال كتابته كما يشاء.

https://plixo-login.**verify-account.co**/login

- https:// — بداية ثابتة
- plixo-login. — ✗ تمويه يكتبه المحتال
- verify-account.co — ✓ الموقع الحقيقي
- /login — المسار — لا يهم

✓ حقيقي — يأخذك إلى plixo.com

```
plixo.com/login
```

✗ مزيّف — يأخذك إلى verify-account.co

```
plixo-login.verify-account.co/login
```

[03] صوّتوا برفع اليد

حقيقي أم مزيّف؟

رسالة SMS · ١ 08:15

«عزيزي العميل، تم إيقاف حسابك البنكي. فعّله خلال ٢٤ ساعة:»

al-rajhi.secure-login.net

واتساب · رقم مجهول · ٢ 14:07

«مبروك! فزت بـ iPhone 16. ادفع ٢٥ ريال رسوم شحن فقط عبر الرابط»

win-prize-now.top

رسالة SMS · ٣ 09:41

رمز التحقق الخاص بك: 480913. لا تشاركه مع أحد.

...لم تطلب أي رمز، ثم يتصل بك شخص «من البنك» يطلبه.

[03] علامات الخطر

٦ علامات تكشف الخدعة

استعجال وتخويف
«حسابك سيُغلق خلال ساعة!»

رابط غريب
عنوان لا ينتهي باسم الجهة الحقيقي

أخطاء وصياغة غريبة
إملاء ركيك أو أسلوب لا يشبه الجهة

يطلب معلومات حسّاسة
كلمة مرور، رمز تحقّق، أو بيانات بطاقة

عرض أجمل من الحقيقة
جائزة في مسابقة لم تشارك فيها

مُرسِل غير متوقّع
رسالة أو مكالمة لم تكن تنتظرها

علامة واحدة تكفي لتتوقّف. **علامتان أو أكثر؟ هي خدعة غالبًا.**

[THE GOLDEN RULE]

وقِّف.. فكِّر.. تحقَّق

١. وقِّف

لا تضغط فورًا — مهما كان الاستعجال.

٢. فكِّر

هل أتوقّع هذه الرسالة؟ هل الرابط منطقي؟

٣. تحقَّق

افتح التطبيق أو الموقع الرسمي بنفسك، أو اتصل بالجهة.

$ sleep 600 && ./resume --part 4

استراحة

نكمل بعد ١٠ دقائق — الجزء القادم: ابنِ درعك

تحدٍّ سريع: افتح إعدادات جوالك، هل عندك تحديث مؤجّل؟

04

[PART 04 · 40 min]

الدرع الرقمي

خطوات بسيطة تجعل اختراقك صعبًا ومكلفًا — فينتقل المهاجم لهدف أسهل

[04] تجربة حيّة LIVE

كم تصمد كلمة مرورك؟

01 امسح الرمز أو اضغط الرابط لفتح الأداة

02 جرّب «123456» ثم جملة طويلة من ٤ كلمات

03 شاهد الزمن يقفز: من «فوري» إلى «قرون»

كلمات وهميّة فقط — الأداة لا تحفظ ولا ترسل شيئًا.



اضغط لفتح الأداة ↗

123456	فوري
7xQ!mz9@Lp	قرون

[04] خط الدفاع الأول

كلمات مرور تصمد

الطول أهم من التعقيد

جملة مرور طويلة تتذكّرها أقوى من رمز قصير معقّد

فريدة لكل حساب

كلمة واحدة لكل المواقع = تسريب واحد يكشفها كلها

مدير كلمات المرور

يصنع ويحفظ كلمات قوية مختلفة — وأنت تتذكّر واحدة فقط

مثال قوي وسهل الحفظ: `Jabal-Tuwaiq-2030!`

[04] أقوى خطوة بأقل جهد

التحقق بخطوتين (2FA)

كلمة المرور
شيء تعرفه

+

رمز من جوالك
شيء تملكه

=

دخول آمن
أنت فقط تملك الاثنين

حتى لو سُرقت كلمة مرورك، **يحتاج المهاجم رمزًا من جوالك — وهو لا يملكه.**

لا تشارك الرمز أبدًا
لا أحد رسميّ يطلب رمزك — ولا حتى البنك

تطبيق مصادقة أفضل من SMS
مثل Google Authenticator

لا توافق على طلب لم تبدأه
تذكّر Uber: ضغطة «موافق» واحدة فتحت الباب

[04] عادات صغيرة، حماية كبيرة

٤ عادات تحميك يوميًا

حدّث فورًا
التحديثات تسدّ الثغرات التي يستغلّها المهاجمون

احذر الواي فاي العام
لا حسابات حسّاسة عليه — أو استخدم VPN موثوقًا أو بيانات جوالك

راجع صلاحيات التطبيقات
لماذا تطلب لعبة الوصول لجهات اتصالك أو ميكروفونك؟

خذ نسخة احتياطية
نسخة لصورك وملفاتك تنقذك من الفقد وبرامج الفدية

[04] خذها معك

درعك الرقمي في ٦ خطوات

صوّر هذه الشريحة

- ✓ كلمة مرور طويلة وفريدة لكل حساب
- ✓ استخدم مدير كلمات مرور
- ✓ فعّل التحقق بخطوتين على البريد والبنك
- ✓ حدّث جهازك وتطبيقاتك فور صدور التحديث
- ✓ VPN أو بيانات الجوال على الواي فاي العام
- ✓ وقِّف.. فكِّر.. تحقَّق قبل أي رابط

05

[PART 05 · 20 min]

دوركم الآن

فكّروا كهاكر أخلاقي، واكتشفوا الخدعة بأنفسكم

[05] سيناريو ٠١ في مجموعات من ٣–٤

حلّلوا هذه الرسالة

⏱ 07:00

واتساب · رقم غير محفوظ

21:03

«جامعة الملك فيصل: مبروك! تم قبولك في منحة بقيمة ٥٠٠٠ ريال. سجّل بياناتك خلال ساعة قبل انتهاء المقاعد:»

kfu-grants.claim-now.info/apply

01 ما العلامات المشبوهة؟

02 ماذا تفعل؟

03 كيف تتأكد؟

[05] سيناريو ٢ · حلّلوا الحادثة

تسريب بيانات النادي الطلابي

١. المشكلة

إعداد مشاركة مفتوح

رابط جدول التسجيل نُشر بصلاحية «أي شخص لديه الرابط» بالخطأ.

٢. الأثر المتوقّع

تسريب البيانات

أسماء الطلاب وأرقامهم مكشوفة للتصيّد الموجّه باسم النادي.

٣. الحل الوقائي

أقل صلاحية ممكنة

اجمع الحد الأدنى من البيانات، واجعل الجدول خاصًا بالمنظّمين فقط.

مبدأ أقل صلاحية (Least Privilege): كل شخص يرى فقط ما يحتاجه لعمله — لا أكثر.

[05] الخلاصة

أهم ٥ أفكار نأخذها اليوم

01 الإذن هو ما يفرّق الهاكر الأخلاقي عن المجرم

02 الشبكة العامة مكشوفة: HTTPS + VPN، والتحميل من المصدر الرسمي فقط

03 المهاجم يستهدف الإنسان أولًا — الشكل يُقلَّد، والرابط هو الحقيقة

04 كلمة مرور طويلة فريدة + تحقق بخطوتين + تحديثات فورية

05 وقّف.. فكّر.. تحقّق — قبل أي ضغطة

[05] خطوتك التالية بعد اليوم

مصادر مفيدة للبداية

هل تسرّب بريدك؟

اكتب بريدك لترى إن ظهر في تسريب سابق — haveibeenpwned.com

أمّن حساب Google الآن

فحص أمان في دقيقتين — Security Checkup

تعلّم الأساسيات

شهادة Google للأمن السيبراني على Coursera

تدرّب عمليًا — بأمان وقانونيًا

مختبرات اختراق أخلاقي للمبتدئين — tryhackme.com

$ exit 0 // you think like a hacker now

شكرًا لكم

أسئلتكم؟

م. محمد الهاشم

مهتمّ بالأمن السيبراني · أخصائي تحليل بيانات ومدرّب

WhatsApp · Telegram · @MN_Alhashem · LinkedIn

Google Developer Group · On Campus · King Faisal University